



Jordan University of Science and Technology (JUST).

Department of Cybersecurity: **CY 411 Reverse Software Engineering**

Date: May. 09.2024

Term Project # 2

Spring 2023-2024

☒ **Problem Statement:** "Disassembling and Analyzing A Windows-based malware using the advanced static tool: The IDA Pro with the virtualized environment."

- Set up a virtualized environment using VMware Player for Windows XP OS.
- Configure your virtual networking using NAT mode.

☒ **Leaders:** Please pass by the instructor to get your malware files using a USB flash drive. Then, start your malware analysis with your team.

☒ **While analyzing your malware, address the following points:**

PART# 1: MAL01.DLL

- What is the address of DllMain?
- Use the Imports window to browse to gethostbyname. Where is the import located?
- How many functions call gethostbyname?
- Focusing on the call to gethostbyname located at 0x10001757, can you figure out which DNS request will be made?
- How many local variables have IDA Pro recognized for the subroutine at 0x10001656?
- How many parameters has IDA Pro recognized for the subroutine at 0x10001656?
- Use the Strings window to locate the string \cmd.exe /c in the disassembly. Where is it located?
- What is happening in the area of code that references \cmd.exe /c?
- In the same area, at 0x100101C8, it looks like dword_1008E5C4 is a global variable that helps decide which path to take. How does the malware set dword_1008E5C4? (Hint: Use dword_1008E5C4's cross-references.)
- A few hundred lines into the subroutine at 0x1000FF58, a series of comparisons use memcmp to compare strings. What happens if the string comparison to robotwork is successful (when memcmp returns 0)?
- What does the export PSLIST do?

- Use the graph mode to graph the cross-references from sub_10004E79. Which API functions could be called by entering this function? Based on the API functions alone, what could you rename this function?
- How many Windows API functions does DllMain call directly? How many at a depth of 2?
- At 0x10001358, there is a call to Sleep (an API function that takes one parameter containing the number of milliseconds to sleep). Looking backward through the code, how long will the program sleep if this code executes?
- At 0x10001701 is a call to the socket. What are the three parameters?
- Using the MSDN page for socket and the named symbolic constants functionality in IDA Pro, can you make the parameters more meaningful? What are the parameters after you apply changes?
- Search for the usage of the in-instruction (opcode 0xED). This instruction is used with a magic string VMXh to perform VMware detection. Is that in use in this malware? Using the cross-references to the function that executes the in-instruction, is there further evidence of VMware detection?
- Jump your cursor to 0x1001D988. What do you find?

PART# 2: MAL02.py

- Download and install the IDA Python plug-in. If you have the IDA Python plug-in installed (included with the commercial version of IDA Pro),
- Run MAL02.py, an IDA Pro Python script, (Make sure the cursor is at 0x1001D988.) What happens after you run the script?
- With the cursor in the same location, how do you turn this data into a single ASCII string?
- Open the script with a text editor. How does it work?

PART# 3: MAL03.exe

- What is the major code construct found in the only subroutine called by main?
- What is the subroutine located at 0x40105F?
- What is the purpose of this program?

PART# 4: MAL04.exe

- What operation does the first subroutine called by the main perform?
- What is the subroutine located at 0x40117F?
- What does the second subroutine call by the main do?
- What type of code construct is used in this subroutine?
- Are there any network-based indicators for this program?
- What is the purpose of this malware?

☒ Finally, after disassembling, dissecting, and analyzing the malware:

- Prepare your incident response technical report by addressing the above points. Provide your insights, conclusions, and recommendations.
- Don't exceed 20 pages: Make your report knowledgeable and sound simple and clear (straight to the point).
- Use snapshots of the different analysis steps. Other analysis tools (for advanced static) are welcomed.
- No presentation is associated with this project. However, students are subject to be asked by the instructor about their work on this project.
- Due Date: May. 23.2024 Before 8:00 PM.